Compliance Assessment Report

ACME Corp (demo)

Generated 2026-10-25 19:39 UTC by examples

Scope: 8 network asset(s), host audit of web-prod-01, traffic capture 'demo:sensor-eth0'

RISK SCORE	SECURITY POSTURE	OPEN FINDINGS	CRITICAL	HIGH	ASSETS	COMPLIANCE	NETWORK HEALTH
100/100	**0/100**	**57**	**13**	**17**	**8**	**9%**	**0/100**

Summary

The assessment identified 57 open finding(s): 13 critical, 17 high, 16 medium and 11 low. The aggregated risk score is 100/100, which corresponds to a critical level of risk. Critical findings must be remediated immediately (P1, 24-72 hours). Overall technical compliance is 9% (critical posture). CIS Critical Security Controls v8: 15% (2 passed, 1 partial, 9 failed, 0 not assessed). NIST Cybersecurity Framework: 12% (1 passed, 0 partial, 10 failed, 0 not assessed). ISO/IEC 27001:2022 Annex A: 0% (0 passed, 0 partial, 10 failed, 0 not assessed). 10 priority-1 gap(s) require immediate attention, notably: CIS-4.1 Establish and Maintain a Secure Configuration Process; CIS-4.4 Implement and Manage a Firewall on Servers; CIS-5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts. 30 finding(s) sit in the high-risk zone of the risk matrix. Network health score of the latest capture is 0/100 with 13 anomaly(ies).

Severity matrix

Category	Critical	High	Medium	Low	Informational	Total
accounts	2			1		3
exposure	1	2	3	2		8
filesystem		1				1
firewall		1				1
logging				1		1
network		1				1
password_policy			2			2
patching				1		1
privilege		1		1		2
ssh		1	2	4		7
traffic	1	4	6	1		12
vulnerability	9	6	3			18
Total	**13**	**17**	**16**	**11**	**0**	**57**

Risk matrix (likelihood x impact)

Likelihood \ Impact	Negligible	Minor	Moderate	Major	Severe
Almost certain				3	11
Likely			3	14	2
Possible			13		
Unlikely		11			
Rare					

Compliance

Framework	Score	Passed	Partial	Failed	Not assessed
CIS Critical Security Controls v8	15%	2	1	9	0
NIST Cybersecurity Framework	12%	1	0	10	0
ISO/IEC 27001:2022 Annex A	0%	0	0	10	0

Gap analysis - CIS Critical Security Controls v8

Priority	Control	Status	Recommendation
P1	CIS-4.1 Establish and Maintain a Secure Configuration Process	FAIL	Adopt a hardened baseline (CIS Benchmark) and enforce it with configuration management.
P1	CIS-4.4 Implement and Manage a Firewall on Servers	FAIL	Enable a default-deny host firewall on every server.
P1	CIS-5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts	FAIL	Disable direct root login, remove duplicate UID 0 accounts and require authentication for sudo.
P1	CIS-7.7 Remediate Detected Vulnerabilities	FAIL	Remediate critical vulnerabilities within 72 hours and high within 7 days.
P2	CIS-3.10 Encrypt Sensitive Data in Transit	FAIL	Use only strong SSH algorithms and replace cleartext services (Telnet, FTP, HTTP) with encrypted alternatives.
P2	CIS-4.3 Configure Automatic Session Locking on Enterprise Assets	FAIL	Configure idle session timeouts (SSH ClientAliveInterval/CountMax, shell TMOUT).
P2	CIS-4.8 Uninstall or Disable Unnecessary Services	FAIL	Remove or disable unneeded network services and bind admin services to management interfaces.
P2	CIS-5.2 Use Unique Passwords	FAIL	Enforce password complexity (minimum 14 characters) and forbid empty passwords.
P2	CIS-8.2 Collect Audit Logs	FAIL	Enable auditd and sudo logging; forward logs to a central collector.
P3	CIS-7.3 Perform Automated Operating System Patch Management	PARTIAL	Enable automatic security updates or a managed patch cycle.

Gap analysis - NIST Cybersecurity Framework

Priority	Control	Status	Recommendation
P1	PR.AA-01 Identities and credentials for authorized users, services, and hardware are managed	FAIL	Review accounts, enforce password policy and lock unused/system accounts.
P1	PR.AA-05 Access permissions are managed, incorporating least privilege	FAIL	Apply least privilege for sudo, root access and sensitive file permissions.
P1	PR.IR-01 Networks and environments are protected from unauthorized logical access and usage	FAIL	Filter inbound traffic with host and network firewalls; restrict exposed services.

Priority	Control	Status	Recommendation
P2	DE.CM-01 Networks and network services are monitored to find potentially adverse events	FAIL	Deploy continuous passive network monitoring and investigate anomalies.
P2	ID.RA-06 Risk responses are chosen, prioritized, planned, tracked, and communicated	FAIL	Prioritise remediation by severity and exploitability and track it to closure.
P2	PR.AA-03 Users, services, and hardware are authenticated	FAIL	Use key-based SSH authentication and limit authentication attempts.
P2	PR.DS-02 The confidentiality, integrity, and availability of data-in-transit are protected	FAIL	Encrypt all administrative and application traffic with modern protocols.
P2	PR.PS-01 Configuration management practices are established and applied	FAIL	Maintain hardened configuration baselines and detect drift automatically.
P2	PR.PS-02 Software is maintained, replaced, and removed commensurate with risk	FAIL	Patch promptly and decommission unsupported software.
P2	PR.PS-04 Log records are generated and made available for continuous monitoring	FAIL	Generate security logs (auditd, sudo) and centralise them.

Gap analysis - ISO/IEC 27001:2022 Annex A

Priority	Control	Status	Recommendation
P1	A.8.2 Privileged access rights	FAIL	Restrict and log privileged access.
P1	A.8.20 Networks security	FAIL	Secure, manage and control networks and filter traffic.
P1	A.8.8 Management of technical vulnerabilities	FAIL	Identify vulnerabilities timely, evaluate exposure and remediate.
P2	A.5.15 Access control	FAIL	Define and enforce access rules based on business and security requirements.
P2	A.5.17 Authentication information	FAIL	Manage passwords through policy (length, ageing, no empty passwords).
P2	A.8.15 Logging	FAIL	Produce, protect and review logs of security events.
P2	A.8.16 Monitoring activities	FAIL	Monitor networks and systems for anomalous behaviour.
P2	A.8.24 Use of cryptography	FAIL	Use approved, modern cryptographic algorithms for data in transit.
P2	A.8.5 Secure authentication	FAIL	Implement secure authentication (keys/MFA, attempt limits).
P2	A.8.9 Configuration management	FAIL	Establish, document and monitor secure configurations.

Findings

CRITICAL Apache HTTP Server 2.4.49 affected by CVE-2021-42013

Identifier	CVE-2021-42013 | CVSS 9.8 | confidence high
Asset	10.10.0.10:80 | vulnerability | vulnerability_analyzer
Description	Incomplete fix for CVE-2021-41773: path traversal and remote code execution in Apache HTTP Server 2.4.49 and 2.4.50. A public exploit is available.
Evidence	80/tcp banner 'Apache httpd 2.4.49 (Unix) OpenSSL/1.0.1f' matches affected range (versions 2.4.49, 2.4.50).
Recommendation	Upgrade Apache HTTP Server to 2.4.51 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2021-42013

CRITICAL Apache HTTP Server 2.4.49 affected by CVE-2022-22720

Identifier	CVE-2022-22720 | CVSS 9.8 | confidence high
Asset	10.10.0.10:80 | vulnerability | vulnerability_analyzer
Description	Apache HTTP Server 2.4.52 and earlier fails to close the inbound connection when errors are encountered discarding the request body, exposing the server to HTTP request smuggling.
Evidence	80/tcp banner 'Apache httpd 2.4.49 (Unix) OpenSSL/1.0.1f' matches affected range (<= 2.4.52).
Recommendation	Upgrade Apache HTTP Server to 2.4.53 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2022-22720

CRITICAL Apache HTTP Server 2.4.49 affected by CVE-2023-25690

Identifier	CVE-2023-25690 | CVSS 9.8 | confidence high
Asset	10.10.0.10:80 | vulnerability | vulnerability_analyzer
Description	Some mod_proxy configurations on Apache HTTP Server 2.4.0 through 2.4.55 allow HTTP request smuggling.
Evidence	80/tcp banner 'Apache httpd 2.4.49 (Unix) OpenSSL/1.0.1f' matches affected range (>= 2.4.0 and <= 2.4.55).
Recommendation	Upgrade Apache HTTP Server to 2.4.56 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2023-25690

CRITICAL OpenSSH 8.9p1 affected by CVE-2023-38408

Identifier	CVE-2023-38408 | CVSS 9.8 | confidence medium
Asset	10.10.0.10:22 | vulnerability | vulnerability_analyzer
Description	The PKCS#11 feature in ssh-agent has an insufficiently trustworthy search path, leading to remote code execution if an agent is forwarded to an attacker-controlled system.
Evidence	22/tcp banner 'OpenSSH 8.9p1 Ubuntu 3ubuntu0.6 Ubuntu Linux; protocol 2.0' matches affected range (< 9.3p2).
Recommendation	Upgrade OpenSSH to 9.3p2 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.
References	https://nvd.nist.gov/vuln/detail/CVE-2023-38408

CRITICAL vsftpd 2.3.4 affected by CVE-2011-2523

Identifier	CVE-2011-2523 | CVSS 9.8 | confidence high
Asset	10.10.0.11:21 | vulnerability | vulnerability_analyzer
Description	vsftpd 2.3.4 downloaded between 2011-06-30 and 2011-07-03 contains a backdoor which opens a shell on port 6200/tcp. A public exploit is available.
Evidence	21/tcp banner 'vsftpd 2.3.4' matches affected range (versions 2.3.4).
Recommendation	Upgrade vsftpd to 2.3.5 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2011-2523

CRITICAL Samba 4.5.9 affected by CVE-2017-7494

Identifier	CVE-2017-7494 | CVSS 9.8 | confidence high
Asset	10.10.0.11:445 | vulnerability | vulnerability_analyzer
Description	SambaCry: a malicious client can upload a shared library to a writable share and cause the server to load and execute it (remote code execution). A public exploit is available.
Evidence	445/tcp banner 'Samba smbd 4.5.9 workgroup: CORP' matches affected range (>= 4.5.0 and < 4.5.10).
Recommendation	Upgrade Samba to 4.6.4 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2017-7494

CRITICAL OpenSSH 7.4 affected by CVE-2023-38408

Identifier	CVE-2023-38408 | CVSS 9.8 | confidence high
Asset	10.10.0.11:22 | vulnerability | vulnerability_analyzer
Description	The PKCS#11 feature in ssh-agent has an insufficiently trustworthy search path, leading to remote code execution if an agent is forwarded to an attacker-controlled system.
Evidence	22/tcp banner 'OpenSSH 7.4 protocol 2.0' matches affected range (< 9.3p2).
Recommendation	Upgrade OpenSSH to 9.3p2 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2023-38408

CRITICAL Exim 4.89 affected by CVE-2019-10149

Identifier	CVE-2019-10149 | CVSS 9.8 | confidence high
Asset	10.10.0.12:25 | vulnerability | vulnerability_analyzer
Description	Improper validation of recipient addresses in deliver_message() in Exim 4.87 to 4.91 allows remote command execution ("Return of the WIZard"). A public exploit is available.
Evidence	25/tcp banner 'Exim smtpd 4.89' matches affected range (>= 4.87 and <= 4.91).
Recommendation	Upgrade Exim to 4.92 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2019-10149

CRITICAL

Apache Tomcat 9.0.30 affected by CVE-2020-1938

Identifier	CVE-2020-1938 | CVSS 9.8 | confidence high
Asset	10.10.0.13:8080 | vulnerability | vulnerability_analyzer
Description	Ghostcat: the AJP connector trusts incoming connections by default, allowing file read/inclusion (and RCE when uploads are possible) in Apache Tomcat. A public exploit is available.
Evidence	8080/tcp banner 'Apache Tomcat 9.0.30' matches affected range (>= 9.0.0.M1 and < 9.0.31).
Recommendation	Upgrade Apache Tomcat to 9.0.31 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2020-1938

CRITICAL

Communication with known malicious IP 203.0.113.50

Identifier	TRF-IOC-IP | confidence high
Asset	10.10.0.13 | traffic | traffic_monitor
Evidence	41943 packets / 62914500 bytes exchanged with 203.0.113.50 (IOC 203.0.113.50, source cybershield-sample: Sample data exfiltration endpoint)
Recommendation	Isolate the host, block the indicator at the perimeter, and start incident response (collect volatile evidence before remediation).

CRITICAL

Docker Engine API exposed without TLS

Identifier	EXP-DOCKER | confidence high
Asset	10.10.0.21:2375 | exposure | vulnerability_analyzer
Description	Docker Engine API exposed without TLS on 10.10.0.21:2375/tcp.
Evidence	2375/tcp docker Docker 20.10.7
Recommendation	Never expose the Docker socket over TCP without mutual TLS; bind to a unix socket only.

CRITICAL

No duplicate UID 0 (root-equivalent) accounts

Identifier	USR-001 | confidence high
Asset	web-prod-01 | accounts | system_auditor
Evidence	Accounts with UID 0 besides root: svc-backup
Recommendation	Only 'root' may have UID 0. Investigate and remove/renumber other UID 0 accounts immediately.
References	CIS Debian/Ubuntu Benchmark 7.2.x | NIST CSF PR.AA-05

CRITICAL

No accounts with empty passwords

Identifier	USR-002 | confidence high
Asset	web-prod-01 | accounts | system_auditor
Evidence	Accounts with empty password: svc-backup
Recommendation	Lock or set a strong password on every account with an empty password field (`passwd -l <user>`).
References	CIS Debian/Ubuntu Benchmark 7.2.x | ISO 27001 A.5.17

HIGH

OpenSSH 8.9p1 affected by CVE-2024-6387

Identifier	CVE-2024-6387 | CVSS 8.1 | confidence medium
Asset	10.10.0.10:22 | vulnerability | vulnerability_analyzer
Description	regreSSHion: a signal handler race condition in sshd's SIGALRM handling (LoginGraceTime) can allow unauthenticated remote code execution as root on glibc-based Linux systems.
Evidence	22/tcp banner 'OpenSSH 8.9p1 Ubuntu 3ubuntu0.6 Ubuntu Linux; protocol 2.0' matches affected range (>= 8.5p1 and < 9.8p1).
Recommendation	Upgrade OpenSSH to 9.8p1 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.
References	https://nvd.nist.gov/vuln/detail/CVE-2024-6387 | https://www.qualys.com/2024/07/01/cve-2024-6387/regresshion.txt

HIGH

OpenSSH 9.7p1 affected by CVE-2024-6387

Identifier	CVE-2024-6387 | CVSS 8.1 | confidence high
Asset	10.10.0.12:22 | vulnerability | vulnerability_analyzer
Description	regreSSHion: a signal handler race condition in sshd's SIGALRM handling (LoginGraceTime) can allow unauthenticated remote code execution as root on glibc-based Linux systems.
Evidence	22/tcp banner 'OpenSSH 9.7p1 protocol 2.0' matches affected range (>= 8.5p1 and < 9.8p1).
Recommendation	Upgrade OpenSSH to 9.8p1 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2024-6387 | https://www.qualys.com/2024/07/01/cve-2024-6387/regresshion.txt

HIGH

nginx 1.18.0 affected by CVE-2021-23017

Identifier	CVE-2021-23017 | CVSS 7.7 | confidence medium
Asset	10.10.0.14:80 | vulnerability | vulnerability_analyzer
Description	A one-byte memory overwrite in the nginx DNS resolver may allow an attacker able to forge UDP packets from the DNS server to crash the worker process or have other impact.
Evidence	80/tcp banner 'nginx 1.18.0 Ubuntu' matches affected range (>= 0.6.18 and < 1.20.1).
Recommendation	Upgrade nginx to 1.20.1 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.
References	https://nvd.nist.gov/vuln/detail/CVE-2021-23017 | https://nginx.org/en/security_advisories.html

HIGH

nginx 1.18.0 affected by CVE-2021-23017

Identifier	CVE-2021-23017 | CVSS 7.7 | confidence medium
Asset	10.10.0.14:443 | vulnerability | vulnerability_analyzer
Description	A one-byte memory overwrite in the nginx DNS resolver may allow an attacker able to forge UDP packets from the DNS server to crash the worker process or have other impact.
Evidence	443/tcp banner 'nginx 1.18.0 Ubuntu' matches affected range (>= 0.6.18 and < 1.20.1).
Recommendation	Upgrade nginx to 1.20.1 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.
References	https://nvd.nist.gov/vuln/detail/CVE-2021-23017 | https://nginx.org/en/security_advisories.html

HIGH

OpenSSL 1.0.1f affected by CVE-2014-0160

Identifier	CVE-2014-0160 | CVSS 7.5 | confidence high
Asset	10.10.0.10:80 | vulnerability | vulnerability_analyzer
Description	Heartbleed: the TLS heartbeat extension in OpenSSL 1.0.1 through 1.0.1f does not properly handle heartbeat requests, disclosing process memory (private keys, credentials). A public exploit is available.
Evidence	80/tcp banner 'Apache httpd 2.4.49 (Unix) OpenSSL/1.0.1f' matches affected range (>= 1.0.1 and <= 1.0.1f).
Recommendation	Upgrade OpenSSL to 1.0.1g or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2014-0160 | https://heartbleed.com/

HIGH

Apache HTTP Server 2.4.49 affected by CVE-2021-41773

Identifier	CVE-2021-41773 | CVSS 7.5 | confidence high
Asset	10.10.0.10:80 | vulnerability | vulnerability_analyzer
Description	Path traversal and file disclosure in Apache HTTP Server 2.4.49 via a flaw in path normalization; can lead to remote code execution when CGI is enabled. A public exploit is available.
Evidence	80/tcp banner 'Apache httpd 2.4.49 (Unix) OpenSSL/1.0.1f' matches affected range (versions 2.4.49).
Recommendation	Upgrade Apache HTTP Server to 2.4.51 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2021-41773 | https://httpd.apache.org/security/vulnerabilities_24.html

HIGH

Redis exposed to the network

Identifier	EXP-REDIS | confidence high
Asset	10.10.0.13:6379 | exposure | vulnerability_analyzer
Description	Redis exposed to the network on 10.10.0.13:6379/tcp.
Evidence	6379/tcp redis Redis key-value store 5.0.7
Recommendation	Bind Redis to 127.0.0.1, enable protected-mode and ACL authentication.

HIGH

Large outbound transfer from 10.10.0.13 to 203.0.113.50

Identifier	TRF-EXFIL | confidence high
Asset	10.10.0.13 | traffic | traffic_monitor
Evidence	60.0 MB sent to external address 203.0.113.50
Recommendation	Verify the transfer is business-justified (backup, update). Otherwise treat as potential data exfiltration: block the destination and review the host.

HIGH

Access to known malicious domain malware-c2.example

Identifier	TRF-IOC-DOMAIN | confidence high
Asset	10.10.0.13 | traffic | traffic_monitor
Evidence	TLS connection (Sample malware command-and-control domain) from 10.10.0.13
Recommendation	Sinkhole/block the domain in DNS, investigate the client for compromise and reset exposed credentials.

HIGH

Telnet service exposed (cleartext credentials)

Identifier	EXP-TELNET | confidence high
Asset	10.10.0.20:23 | exposure | vulnerability_analyzer
Description	Telnet service exposed (cleartext credentials) on 10.10.0.20:23/tcp.
Evidence	23/tcp telnet Linux telnetd
Recommendation	Disable Telnet and use SSH with key-based authentication.

HIGH

Possible DNS tunnelling via tunnel-exfil.example

Identifier	TRF-DNS-TUNNEL | confidence high
Asset	10.10.0.56 | traffic | traffic_monitor
Evidence	60 unique sub-domains queried under tunnel-exfil.example with very long query names
Recommendation	Block the domain, inspect the client, and restrict DNS egress to internal resolvers only.

HIGH

Possible port scan from 10.10.0.99

Identifier	TRF-PORTSCAN | confidence high
Asset	10.10.0.99 | traffic | traffic_monitor
Evidence	30+ distinct SYN probes to 1 host(s): 10.10.0.10
Recommendation	Confirm whether the scan is authorised; if not, block the source and investigate the host.

HIGH

Critical system files have restrictive permissions

Identifier	FS-001 | confidence high
Asset	web-prod-01 | filesystem | system_auditor
Evidence	/etc/shadow mode 0o644 must not be accessible by others
Recommendation	Restore permissions: `chmod 644 /etc/passwd /etc/group; chmod 640 /etc/shadow /etc/gshadow; chmod 440 /etc/sudoers; chmod 600 /etc/ssh/sshd_config`.
References	CIS Debian/Ubuntu Benchmark 7.1

HIGH

Host firewall is enabled

Identifier	FW-001 | confidence high
Asset	web-prod-01 | firewall | system_auditor
Evidence	ufw is installed but disabled (ENABLED=no in /etc/ufw/ufw.conf)
Recommendation	Enable a default-deny host firewall (e.g. `ufw default deny incoming && ufw enable`, or nftables with an input chain policy of drop) and allow only required services.
References	CIS Controls v8 4.4 | CIS Debian/Ubuntu Benchmark 3.5

HIGH

No high-risk services listening on all interfaces

Identifier	NET-001 | confidence high
Asset	web-prod-01 | network | system_auditor
Evidence	Exposed on all interfaces: tcp/3306 MySQL
Recommendation	Bind databases and admin services to localhost or a management interface, disable cleartext protocols (Telnet/FTP/rsh) and restrict access with the host firewall.
References	CIS Controls v8 4.8 | NIST CSF PR.IR-01

HIGH

SSH root login is disabled

Identifier	SSH-001 | confidence high
Asset	web-prod-01 | ssh | system_auditor
Evidence	PermitRootLogin yes
Recommendation	Set `PermitRootLogin no` in /etc/ssh/sshd_config and administer via named accounts + sudo.
References	CIS Debian/Ubuntu Benchmark 5.1 | ISO 27001 A.8.5

HIGH

sudo always requires authentication (no NOPASSWD)

Identifier	SUDO-001 | confidence high
Asset	web-prod-01 | privilege | system_auditor
Evidence	Passwordless sudo rules: /etc/sudoers.d/deploy: bob ALL=(ALL) NOPASSWD: ALL
Recommendation	Remove NOPASSWD and !authenticate from sudoers rules (use `visudo`); grant passwordless sudo only to narrowly scoped automation commands.
References	CIS Debian/Ubuntu Benchmark 5.2.4 | ISO 27001 A.8.2

MEDIUM

OpenSSH 8.9p1 affected by CVE-2023-48795

Identifier	CVE-2023-48795 | CVSS 5.9 | confidence medium
Asset	10.10.0.10:22 | vulnerability | vulnerability_analyzer
Description	Terrapin: the SSH transport protocol with certain OpenSSH extensions allows remote attackers to bypass integrity checks (prefix truncation), downgrading connection security. A public exploit is available.
Evidence	22/tcp banner 'OpenSSH 8.9p1 Ubuntu 3ubuntu0.6 Ubuntu Linux; protocol 2.0' matches affected range (< 9.6p1).
Recommendation	Upgrade OpenSSH to 9.6p1 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.
References	https://nvd.nist.gov/vuln/detail/CVE-2023-48795 | https://terrapin-attack.com/

MEDIUM

OpenSSH 7.4 affected by CVE-2023-48795

Identifier	CVE-2023-48795 | CVSS 5.9 | confidence high
Asset	10.10.0.11:22 | vulnerability | vulnerability_analyzer
Description	Terrapin: the SSH transport protocol with certain OpenSSH extensions allows remote attackers to bypass integrity checks (prefix truncation), downgrading connection security. A public exploit is available.
Evidence	22/tcp banner 'OpenSSH 7.4 protocol 2.0' matches affected range (< 9.6p1).
Recommendation	Upgrade OpenSSH to 9.6p1 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2023-48795 | https://terrapin-attack.com/

MEDIUM

OpenSSH 7.4 affected by CVE-2018-15473

Identifier	CVE-2018-15473 | CVSS 5.3 | confidence high
Asset	10.10.0.11:22 | vulnerability | vulnerability_analyzer
Description	OpenSSH through 7.7 is prone to a user enumeration vulnerability due to not delaying bailout for an invalid authenticating user. A public exploit is available.
Evidence	22/tcp banner 'OpenSSH 7.4 protocol 2.0' matches affected range (<= 7.7).
Recommendation	Upgrade OpenSSH to 7.8 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2018-15473

MEDIUM

Database service reachable over the network

Identifier	EXP-DATABASE | confidence high
Asset	10.10.0.10:3306 | exposure | vulnerability_analyzer
Description	Database service reachable over the network on 10.10.0.10:3306/tcp.
Evidence	3306/tcp mysql MySQL 8.0.36
Recommendation	Restrict database ports to application servers via firewall rules and require TLS.

MEDIUM

FTP service exposed (cleartext credentials)

Identifier	EXP-FTP | confidence high
Asset	10.10.0.11:21 | exposure | vulnerability_analyzer
Description	FTP service exposed (cleartext credentials) on 10.10.0.11:21/tcp.
Evidence	21/tcp ftp vsftpd 2.3.4
Recommendation	Replace FTP with SFTP/FTPS; if FTP is required, disable anonymous access.

MEDIUM

SMB/NetBIOS file sharing exposed

Identifier	EXP-SMB | confidence high
Asset	10.10.0.11:445 | exposure | vulnerability_analyzer
Description	SMB/NetBIOS file sharing exposed on 10.10.0.11:445/tcp.
Evidence	445/tcp netbios-ssn Samba smbd 4.5.9
Recommendation	Disable SMBv1, require SMB signing and restrict SMB to trusted segments.

MEDIUM

Legacy TLS/SSL protocol in use

Identifier	TRF-LEGACY-TLS | confidence high
Asset	10.10.0.53 | traffic | traffic_monitor
Evidence	10.10.0.53 -> legacy-portal.example.org (TLS 1.0)
Recommendation	Disable SSL 3.0/TLS 1.0/1.1 on clients and servers; require TLS 1.2+ (RFC 8996).

MEDIUM

Algorithmically generated (DGA-like) domain lookups

Identifier	TRF-DGA | confidence high
Asset	10.10.0.55 | traffic | traffic_monitor
Evidence	41 high-entropy domain(s): 08v56nsn0jf37650.example, 0z5hfsmgdw5820cz.example, 1ds0lrw96d2ln4kv.example, 3bdlrskcchmpvxgd.example, 3dgktw07zzdlj99j.example, 4pw2vvz4hq7528kd.example, 57dr5chwn159gtgv.example, 66zsnd6cl7zc12lx.example, 6xg7qh0gm9k6zk3j.example, 778zjm7gwvlxtjrw.example
Recommendation	Inspect the querying hosts for malware; enable DNS filtering / RPZ.

MEDIUM

Connection attempt to suspicious port 4444

Identifier	TRF-SUSP-PORT | confidence high
Asset	10.10.0.57 | traffic | traffic_monitor
Evidence	10.10.0.57 -> 198.51.100.200:4444 (Metasploit default handler)
Recommendation	Identify the process initiating the connection; block the port at the egress firewall if unused.

MEDIUM

Connection attempt to suspicious port 23

Identifier	TRF-SUSP-PORT | confidence high
Asset	10.10.0.99 | traffic | traffic_monitor
Evidence	10.10.0.99 -> 10.10.0.10:23 (Telnet)
Recommendation	Identify the process initiating the connection; block the port at the egress firewall if unused.

MEDIUM

High rate of failed DNS resolutions (NXDOMAIN)

Identifier	TRF-NXDOMAIN | confidence high
Asset	network | traffic | traffic_monitor
Evidence	45/135 responses were NXDOMAIN
Recommendation	Investigate clients generating failed lookups (DGA malware, misconfiguration).

MEDIUM

Unexpected traffic spike

Identifier	TRF-SPIKE | confidence high
Asset	network | traffic | traffic_monitor
Evidence	20987369 bytes in 10s at 2026-10-25T19:36:20+00:00 = 1360.6x the median baseline (15425 bytes)
Recommendation	Correlate with top talkers at that time; check for DoS, misbehaving jobs or exfiltration.

MEDIUM

Password aging policy is enforced

Identifier	PWD-001 | confidence high
Asset	web-prod-01 | password_policy | system_auditor
Evidence	PASS_MAX_DAYS=99999 (> 365); PASS_MIN_DAYS=0 (< 1)
Recommendation	In /etc/login.defs set PASS_MAX_DAYS 365 (or less), PASS_MIN_DAYS 1 and PASS_WARN_AGE 7.
References	CIS Debian/Ubuntu Benchmark 5.4.1 | ISO 27001 A.5.17

MEDIUM

Password complexity is enforced (pam_pwquality)

Identifier	PWD-003 | confidence high
Asset	web-prod-01 | password_policy | system_auditor
Evidence	No pam_pwquality/pam_cracklib module in the PAM password stack
Recommendation	Install libpam-pwquality, reference pam_pwquality.so in the PAM password stack and set minlen = 14 in /etc/security/pwquality.conf.
References	CIS Debian/Ubuntu Benchmark 5.3.3.2 | CIS Controls v8 5.2

MEDIUM

SSH password authentication is disabled

Identifier	SSH-002 | confidence high
Asset	web-prod-01 | ssh | system_auditor
Evidence	PasswordAuthentication yes (brute-force exposure)
Recommendation	Deploy SSH keys, then set `PasswordAuthentication no` and `KbdInteractiveAuthentication no`.
References	CIS Debian/Ubuntu Benchmark 5.1 | ISO 27001 A.8.5

MEDIUM

SSH uses strong cryptographic algorithms only

Identifier	SSH-006 | confidence high
Asset	web-prod-01 | ssh | system_auditor
Evidence	Weak algorithms enabled: ciphers: aes128-cbc
Recommendation	Remove CBC/arcfour/3DES ciphers, MD5/SHA1-96 MACs and SHA-1 key exchanges from Ciphers, MACs and KexAlgorithms (or rely on modern OpenSSH defaults).
References	CIS Debian/Ubuntu Benchmark 5.1 | ISO 27001 A.8.5 | CIS Controls v8 3.10

LOW

Web service without HTTPS

Identifier	EXP-HTTP-NOTLS | confidence high
Asset	10.10.0.10:80 | exposure | vulnerability_analyzer
Description	HTTP on port 80 and no HTTPS listener detected on the host.
Evidence	80/tcp Apache httpd 2.4.49
Recommendation	Enable HTTPS with a valid certificate and redirect HTTP to HTTPS (HSTS).

LOW

Web service without HTTPS

Identifier	EXP-HTTP-NOTLS | confidence high
Asset	10.10.0.13:8080 | exposure | vulnerability_analyzer
Description	HTTP on port 8080 and no HTTPS listener detected on the host.
Evidence	8080/tcp Apache Tomcat 9.0.30
Recommendation	Enable HTTPS with a valid certificate and redirect HTTP to HTTPS (HSTS).

LOW

Cleartext HTTP to Internet hosts

Identifier	TRF-CLEARTEXT-HTTP | confidence high
Asset	10.10.0.54 | traffic | traffic_monitor
Evidence	1 client/host pairs, e.g. downloads.example.net
Recommendation	Enforce HTTPS (HSTS, browser policies, egress proxy) to protect data in transit.

LOW

System auditing (auditd) is installed

Identifier	LOG-001 | confidence high
Asset	web-prod-01 | logging | system_auditor
Evidence	auditd configuration not found
Recommendation	Install and enable auditd (`apt install auditd && systemctl enable --now auditd`) with rules for identity, sudoers and authentication events.
References	CIS Controls v8 8.2 | ISO 27001 A.8.15

LOW

SSH MaxAuthTries is 4 or less

Identifier	SSH-004 | confidence high
Asset	web-prod-01 | ssh | system_auditor
Evidence	MaxAuthTries 6 (> 4)
Recommendation	Set `MaxAuthTries 4` to slow down online guessing.
References	CIS Debian/Ubuntu Benchmark 5.1 | ISO 27001 A.8.5

LOW

SSH X11 forwarding is disabled

Identifier	SSH-005 | confidence high
Asset	web-prod-01 | ssh | system_auditor
Evidence	X11Forwarding yes
Recommendation	Set `X11Forwarding no` unless strictly required.
References	CIS Debian/Ubuntu Benchmark 5.1 | ISO 27001 A.8.5

LOW

SSH idle session timeout is configured

Identifier	SSH-007 | confidence high
Asset	web-prod-01 | ssh | system_auditor
Evidence	ClientAliveInterval 0 (idle sessions never time out)
Recommendation	Set `ClientAliveInterval 300` and `ClientAliveCountMax 3` (idle sessions closed after ~15 min).
References	CIS Debian/Ubuntu Benchmark 5.1 | ISO 27001 A.8.5 | CIS Controls v8 4.3

LOW

SSH LoginGraceTime is 60 seconds or less

Identifier	SSH-008 | confidence high
Asset	web-prod-01 | ssh | system_auditor
Evidence	LoginGraceTime 120
Recommendation	Set `LoginGraceTime 60` to limit unauthenticated connection slots (also mitigates some DoS/race attacks).
References	CIS Debian/Ubuntu Benchmark 5.1 | ISO 27001 A.8.5

LOW

sudo uses a pseudo-terminal and logs to a file

Identifier	SUDO-002 | confidence high
Asset	web-prod-01 | privilege | system_auditor
Evidence	Missing sudo Defaults: use_pty, logfile
Recommendation	Add `Defaults use_pty` and `Defaults logfile="/var/log/sudo.log"` to /etc/sudoers.d/hardening.
References	CIS Debian/Ubuntu Benchmark 5.2.2-5.2.3

LOW

Automatic security updates are configured

Identifier	UPD-001 | confidence high
Asset	web-prod-01 | patching | system_auditor
Evidence	No automatic security update mechanism detected
Recommendation	Debian/Ubuntu: `apt install unattended-upgrades && dpkg-reconfigure -plow unattended-upgrades`. RHEL family: enable dnf-automatic with apply_updates = yes. On rolling distributions (Kali/Parrot) schedule regular `apt full-upgrade` instead.
References	CIS Controls v8 7.3 | NIST CSF PR.PS-02

LOW

System accounts have no interactive shell

Identifier	USR-003 | confidence high
Asset	web-prod-01 | accounts | system_auditor
Evidence	System accounts with a login shell: postgres. Interactive accounts: alice, bob, root, svc-backup
Recommendation	Set the shell of service/system accounts to /usr/sbin/nologin (`usermod -s /usr/sbin/nologin <user>`).
References	CIS Debian/Ubuntu Benchmark 5.4.2

Recommendations

1. Adopt a hardened baseline (CIS Benchmark) and enforce it with configuration management.
2. Enable a default-deny host firewall on every server.
3. Disable direct root login, remove duplicate UID 0 accounts and require authentication for sudo.
4. Remediate critical vulnerabilities within 72 hours and high within 7 days.
5. Review accounts, enforce password policy and lock unused/system accounts.
6. Apply least privilege for sudo, root access and sensitive file permissions.
7. Filter inbound traffic with host and network firewalls; restrict exposed services.
8. Restrict and log privileged access.
9. Secure, manage and control networks and filter traffic.

10. Identify vulnerabilities timely, evaluate exposure and remediate.
11. Use only strong SSH algorithms and replace cleartext services (Telnet, FTP, HTTP) with encrypted alternatives.
12. Configure idle session timeouts (SSH ClientAliveInterval/CountMax, shell TMOUT).

Remediation priorities

Priority	Severity	Target	Count	Examples
P1 Immediate	CRITICAL	Within 24-72 hours	13	Apache HTTP Server 2.4.49 affected by CVE-2021-42013 (10.10.0.10); Apache HTTP Server 2.4.49 affected by CVE-2022-22720 (10.10.0.10); Apache HTTP Server 2.4.49 affected by CVE-2023-25690 (10.10.0.10); OpenSSH 8.9p1 affected by CVE-2023-38408 (10.10.0.10); vsftpd 2.3.4 affected by CVE-2011-2523 (10.10.0.11)
P2 Urgent	HIGH	Within 7 days	17	OpenSSH 8.9p1 affected by CVE-2024-6387 (10.10.0.10); OpenSSH 9.7p1 affected by CVE-2024-6387 (10.10.0.12); nginx 1.18.0 affected by CVE-2021-23017 (10.10.0.14); nginx 1.18.0 affected by CVE-2021-23017 (10.10.0.14); OpenSSL 1.0.1f affected by CVE-2014-0160 (10.10.0.10)
P3 Planned	MEDIUM	Within 30 days	16	OpenSSH 8.9p1 affected by CVE-2023-48795 (10.10.0.10); OpenSSH 7.4 affected by CVE-2023-48795 (10.10.0.11); OpenSSH 7.4 affected by CVE-2018-15473 (10.10.0.11); Database service reachable over the network (10.10.0.10); FTP service exposed (cleartext credentials) (10.10.0.11)
P4 Routine	LOW	Within 90 days	11	Web service without HTTPS (10.10.0.10); Web service without HTTPS (10.10.0.13); Cleartext HTTP to Internet hosts (10.10.0.54); System auditing (auditd) is installed (web-prod-01); SSH MaxAuthTries is 4 or less (web-prod-01)

Produced by CyberShield 1.0.0 for authorised defensive use only. Automated findings should be validated by a qualified analyst before remediation decisions.